Universidad Nacional de Costa Rica
Facultad de Ciencias Exactas y Naturales
Escuela de Informática
EIF402 Administración de Bases de Datos

AUDINC

Controles ISO/IEC 27001:2022 para la confidencialidad en la administración de bases de datos Oracle

Evaluador de controles observables con matriz de madurez 0 a 4

Informe del proyecto

Profesor: Johnny Villalobos Murillo

Estudiante: Isaac Naranjo

Repositorio: https://github.com/Isaac-Naranjo/AUDINC

II Ciclo 2026 · Heredia, Costa Rica · Octubre de 2026

Informe del proyecto AUDINC

Índice

1. Introducción
2. Objetivos
    - 2.1 Objetivo general
    - 2.2 Objetivos específicos y su cumplimiento
3. Marco teórico
    - 3.1 ISO/IEC 27001:2022 y sus cambios respecto a la versión 2013
    - 3.2 Mínimo privilegio y separación de funciones
    - 3.3 Defensa en profundidad y Zero Trust aplicados a bases de datos
    - 3.4 Controles técnicos de confidencialidad
    - 3.5 Prevención de fuga de datos y respaldos cifrados
    - 3.6 Registro, monitoreo y correlación (SIEM)
    - 3.7 Normativa costarricense: Ley 8968
4. Metodología y herramientas
    - 4.1 Ciclo PHVA
    - 4.2 Herramientas
    - 4.3 Entorno de prueba
5. El artefacto
    - 5.1 Descripción
    - 5.2 Tabla de riesgos de confidencialidad
    - 5.3 Tabla de tareas del DBA
    - 5.4 Mapeo de controles ISO/IEC 27001:2022
    - 5.5 Controles observables por un auditor externo
    - 5.6 Criterio de madurez 0 a 4
    - 5.7 Matriz de evaluación
    - 5.8 Batería de pruebas
    - 5.9 Auditoría de las cuentas de usuario
    - 5.10 Excepciones aprobadas
6. Resultados
    - 6.1 Evolución de las evaluaciones
    - 6.2 Detalle de la evaluación final (#42)
    - 6.3 Acciones correctivas (fase Actuar)
    - 6.4 Prueba de detección y corrección (PT-23)
7. Conclusiones y recomendaciones
    - 7.1 Conclusiones
    - 7.2 Recomendaciones y trabajo futuro
8. Uso ético y documentado de inteligencia artificial
    - Declaración jurada
9. Referencias

Anexo A. Consultas de evidencia de los controles observables

Anexo B. Scripts entregados

1. Introducción

La confidencialidad es la propiedad de la información que garantiza que solo las personas autorizadas puedan conocerla. En una organización, los datos más sensibles (identificación de clientes, salarios, datos de contacto) suelen residir en una base de datos, y el Administrador de Bases de Datos (DBA) es su custodio técnico: crea las cuentas, otorga los privilegios, configura los respaldos y decide qué se registra en la auditoría. Cada una de esas tareas, mal ejecutada, abre una vía para que la información llegue a quien no debe.

Este proyecto diseña e implementa un marco de controles basado en ISO/IEC 27001:2022 (Anexo A) e ISO/IEC 27002:2022 para mitigar los riesgos de confidencialidad en las tareas del DBA sobre Oracle Database 21c Express Edition. El resultado es **AUDINC**, un artefacto interactivo que:

- documenta 5 riesgos de confidencialidad, 12 tareas críticas del DBA y el mapeo a 18 controles del Anexo A (15 solicitados y 3 complementarios);
- ejecuta 16 controles observables (consultas al diccionario de datos de Oracle que cualquier auditor externo puede repetir) y los califica con un criterio de madurez de 0 a 4;
- llena automáticamente la matriz de evaluación (Tarea, Riesgo, Control, Criterio 0 a 4, Evidencia, Estado) y guarda un histórico que no puede alterarse;
- audita cada cuenta de usuario de Oracle contra los requisitos de confidencialidad que le aplican.

El trabajo se organizó con el ciclo PHVA (Planificar, Hacer, Verificar, Actuar). La primera evaluación, sobre una base con brechas intencionales, obtuvo 2 de 16 controles en estado Cumple; la evaluación final obtuvo 16 de 16.

2. Objetivos

2.1 Objetivo general

Diseñar e implementar un marco de controles basado en ISO/IEC 27001:2022 (Anexo A) e ISO/IEC 27002:2022 para mitigar riesgos de confidencialidad en las tareas del Administrador de Bases de Datos, incluyendo una matriz de evaluación y pruebas observables auditables.

2.2 Objetivos específicos y su cumplimiento

Objetivo específico	Cómo se cumple	Sección
Identificar y clasificar al menos 5 riesgos de confidencialidad (R-CONF) en Oracle	5 riesgos con impacto, probabilidad y nivel	5.2
Mapear al menos 12 tareas críticas del DBA	12 tareas relacionadas con riesgos y controles	5.3
Seleccionar y justificar los controles del Anexo A 2022	15 controles solicitados y 3 complementarios (A8.24, A8.8, A8.33)	5.4
Diseñar una matriz de evaluación con madurez 0 a 4, evidencia y estado	Matriz generada por el evaluador en cada ejecución	5.6 y 5.7
Proponer y ejecutar pruebas técnicas que demuestren la efectividad	23 pruebas: 16 de consulta y 7 funcionales, con scripts y salidas	5.8

3. Marco teórico

3.1 ISO/IEC 27001:2022 y sus cambios respecto a la versión 2013

ISO/IEC 27001 especifica los requisitos de un Sistema de Gestión de Seguridad de la Información (SGSI). Su Anexo A contiene los controles de referencia, que ISO/IEC 27002 desarrolla con guías de implementación. La versión 2022 reorganizó el Anexo A: pasó de 114 controles en 14 dominios (2013) a **93 controles agrupados en 4 temas**: organizacionales (5.1 a 5.37), de personas (6.1 a 6.8), físicos (7.1 a 7.14) y tecnológicos (8.1 a 8.34) (International Organization for Standardization [ISO], 2022a). Varios controles se fusionaron y se incorporaron 11 controles nuevos, entre ellos tres que son centrales para este proyecto: **A8.10 Eliminación de información**, **A8.11 Enmascaramiento de datos** y **A8.12 Prevención de fuga de datos** (ISO, 2022b).

ISO/IEC 27002:2022 también introdujo **atributos** para cada control (tipo de control, propiedades de seguridad, conceptos de ciberseguridad, capacidades operativas y dominios de seguridad). El atributo de propiedades de seguridad permite filtrar los controles que protegen la **confidencialidad**, que es el criterio usado para seleccionar los controles de este trabajo.

En clase se trabajó con la numeración 2013; su equivalencia en 2022 es la siguiente: A.9.2 (gestión de acceso de usuarios) corresponde a A5.16, A5.18 y A8.2; A.9.4 (control de acceso a sistemas y aplicaciones) a A8.3 y A8.5; A.10.1 (controles criptográficos) a A8.24; y A.8.1 (responsabilidad sobre los activos) a A5.9.

3.2 Mínimo privilegio y separación de funciones

El principio de mínimo privilegio establece que cada programa y cada usuario debe operar con el menor conjunto de privilegios necesario para su trabajo (Saltzer y Schroeder, 1975). En Oracle se aplica otorgando privilegios a **roles** (`CREATE ROLE vendedor`) y roles a usuarios, en lugar de conceder privilegios directos, de sistema (`SELECT ANY TABLE`) o a `PUBLIC`. Así los derechos pueden revisarse y retirarse por función (A5.15, A5.18, A8.2).

La **separación de funciones** evita que una misma persona pueda ejecutar y ocultar una acción indebida. En el rol del DBA esto significa que quien administra la base no debe poder borrar el rastro de auditoría: Oracle separa los roles `AUDIT_ADMIN` (configura y purga la auditoría) y `AUDIT_VIEWER` (solo la consulta) de los privilegios administrativos ordinarios (A5.33). En AUDINC, la cuenta del evaluador solo puede insertar y leer resultados; un intento de modificarlos devuelve `ORA-01031`.

3.3 Defensa en profundidad y Zero Trust aplicados a bases de datos

La defensa en profundidad superpone controles independientes para que la falla de uno no exponga los datos. En AUDINC las capas son: red (cifrado del tráfico, A8.20), autenticación (perfiles de contraseña, A8.5), autorización (roles y VPD, A5.18 y A8.3), datos (Data Redaction y TDE, A8.11 y A8.24) y monitoreo (auditoría unificada, A8.15).

Zero Trust parte de no conceder confianza implícita por la ubicación en la red: cada solicitud debe autenticarse y autorizarse de forma explícita, con el menor privilegio posible (Rose et al., 2020). La aplicación AUDINC lo aplica al no almacenar contraseñas: cada inicio de sesión se valida abriendo una sesión en Oracle con la cuenta del usuario, cada petición verifica la sesión y el rol `AUDITOR`, y cada consulta queda identificada con el usuario final mediante `DBMS_SESSION.SET_IDENTIFIER`.

3.4 Controles técnicos de confidencialidad

- **Transparent Data Encryption (TDE).** Cifra los datos almacenados (datafiles, y con ellos sus copias de respaldo) sin cambios en la aplicación. Usa una arquitectura de dos niveles: una llave maestra guardada en un keystore externo a la base cifra las llaves de cada tablespace. En una base multitenant el keystore funciona en modo unido, con una llave maestra por contenedor (Oracle, 2021a). Protege contra el robo de archivos o discos, no contra un usuario con permisos de lectura.
- **Enmascaramiento dinámico y Data Redaction.** El enmascaramiento dinámico oculta el valor real al momento de la consulta. En Oracle se implementa con Data Redaction (`DBMS_REDACT`): el dato no cambia en disco, pero quien no tiene el privilegio `EXEMPT REDACTION POLICY` lo recibe total o parcialmente oculto (Oracle, 2021a). El enmascaramiento estático, en cambio, reemplaza los datos de forma permanente y se usa al crear copias para desarrollo y pruebas (A8.33).
- **Row Level Security / Virtual Private Database (VPD).** Una función de política (`DBMS_RLS.ADD_POLICY`) agrega un predicado a cada sentencia, de modo que cada usuario ve solo las filas que le corresponden (Oracle, 2021b).
- **Cifrado de las conexiones.** Oracle ofrece cifrado nativo de red (Native Network Encryption), configurado en `sqlnet.ora` sin certificados, y TLS (TCPS), que además autentica al servidor mediante certificados (Oracle, 2021a). AUDINC aplica el cifrado nativo con AES-256 e integridad SHA-256 obligatorios.

3.5 Prevención de fuga de datos y respaldos cifrados

La prevención de fuga de datos (DLP, A8.12) busca cerrar las vías por las que la información puede salir de la base sin control. En Oracle, los paquetes `UTL_FILE`, `UTL_HTTP`, `UTL_TCP` y `UTL_SMTP` permiten escribir archivos o enviar datos por la red; por defecto pueden ser ejecutados por `PUBLIC`. Revocar ese permiso reduce la superficie de extracción, aunque debe hacerse con cuidado porque componentes internos de Oracle dependen de ellos (ver la acción correctiva AC-01). Los respaldos son la otra gran vía de fuga: una copia RMAN o un export de Data Pump sin cifrar contiene toda la información. RMAN admite cifrado transparente (con el keystore de TDE), por contraseña o dual (A8.13).

3.6 Registro, monitoreo y correlación (SIEM)

Sin registro no hay forma de investigar un acceso indebido. Oracle Database 21c incluye la **auditoría unificada**: políticas declarativas (`CREATE AUDIT POLICY`, `AUDIT POLICY`) cuyos eventos se consultan en `UNIFIED_AUDIT_TRAIL`, junto con políticas predefinidas como `ORA_LOGON_FAILURES` (intentos fallidos de inicio de sesión) (Oracle, 2021b). La gestión de registros recomienda además centralizarlos, protegerlos contra modificación y analizarlos de forma periódica (Kent y Souppaya, 2006). Un SIEM (Security Information and Event Management) correlaciona eventos de distintas fuentes para detectar patrones. Como mejora futura se propone copiar el rastro de auditoría a un sistema separado, de modo que un administrador con privilegios no pueda borrar sus propias huellas sin que se note (sección 7.2).

3.7 Normativa costarricense: Ley 8968

La Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales (Ley N.° 8968) regula el tratamiento de datos personales en bases de datos públicas y privadas, y creó la Agencia de Protección de Datos de los Habitantes (PRODHAB) (Asamblea Legislativa de la República de Costa Rica, 2011). La ley obliga al responsable de una base de datos a adoptar medidas técnicas y organizativas que garanticen la seguridad de los datos y eviten su acceso no autorizado (artículo 10), e impone un deber de confidencialidad a quienes intervienen en el tratamiento (artículo 11). Su reglamento (Decreto Ejecutivo N.°

37554-JP) detalla esas medidas (Poder Ejecutivo de la República de Costa Rica, 2013). Los datos de prueba de AUDINC (cédula, correo, teléfono, dirección y salario) son ficticios, pero representan justamente los datos personales que la ley protege.

4. Metodología y herramientas

4.1 Ciclo PHVA

Fase	Qué se hizo	Evidencia en el repositorio
Planificar	Verificación del entorno, catálogo de riesgos, tareas y controles, esquema de prueba con datos ficticios y brechas intencionales, cuenta del evaluador con mínimo privilegio	`scripts/00_setup/`, `docs/catalogo_controles.md`
Hacer	Aplicación de los controles: clasificación, privilegios, cuentas, perfiles, VPD, eliminación segura, Data Redaction, prevención de fuga, auditoría, cifrado de red y TDE	`scripts/01_controles/`
Verificar	Evaluaciones con las 16 consultas de evidencia y pruebas funcionales PT-17 a PT-23	`scripts/02_verificacion/`, `tests/`, `evidencias/salidas/`
Actuar	Acciones correctivas AC-01 a AC-04 y excepciones aprobadas con vencimiento	`scripts/03_correccion/`

4.2 Herramientas

Herramienta	Uso
Oracle Database 21c Express Edition (21.3), PDB `XEPDB1`	Motor de base de datos evaluado
SQL Developer y SQL*Plus	Ejecución de scripts y pruebas funcionales
PHP 8.3 con la extensión OCI8	Evaluador web (servidor integrado de PHP, sin Apache)
HTML, CSS y JavaScript sin frameworks	Interfaz web del artefacto
Git y GitHub	Control de versiones y repositorio del proyecto
Claude (Anthropic) mediante Claude Code	Asistente de IA, documentado en la sección 8

4.3 Entorno de prueba

La instancia XE es compartida con otros proyectos del curso. Todo AUDINC vive en la PDB `XEPDB1`, con tres esquemas sin contraseña (`NO AUTHENTICATION`): `AUDINC_DEMO` (datos de negocio ficticios), `AUDINC_OWNER` (catálogo y resultados) y `AUDINC_SEC` (función de la política VPD). Los usuarios de prueba son `JUAN` y `PEDRO` (rol `VENDEDOR`), `LUIS` (rol `SUPERVISOR`), `ISAAC` (rol `AUDITOR`, cuenta nominal del responsable de la auditoría) y `TEMPORAL` (cuenta sin uso). La aplicación se conecta con la cuenta de servicio `AUDINC_APP`, que solo puede leer el diccionario y el catálogo e insertar resultados.

5. El artefacto

5.1 Descripción

AUDINC es una aplicación web que se ejecuta localmente (`php -S localhost:8000 -t public public/index.php`) y a la que se ingresa con una cuenta de Oracle que tenga el rol `AUDITOR`. El botón **Ejecutar evaluación** corre las 16 consultas de evidencia contra el diccionario de datos, califica cada control y guarda el resultado a nombre del auditor. El código, los scripts y las evidencias están en https://github.com/Isaac-Naranjo/AUDINC. El uso de la aplicación se describe en el *Manual de usuario* y su instalación en el *Manual técnico*.

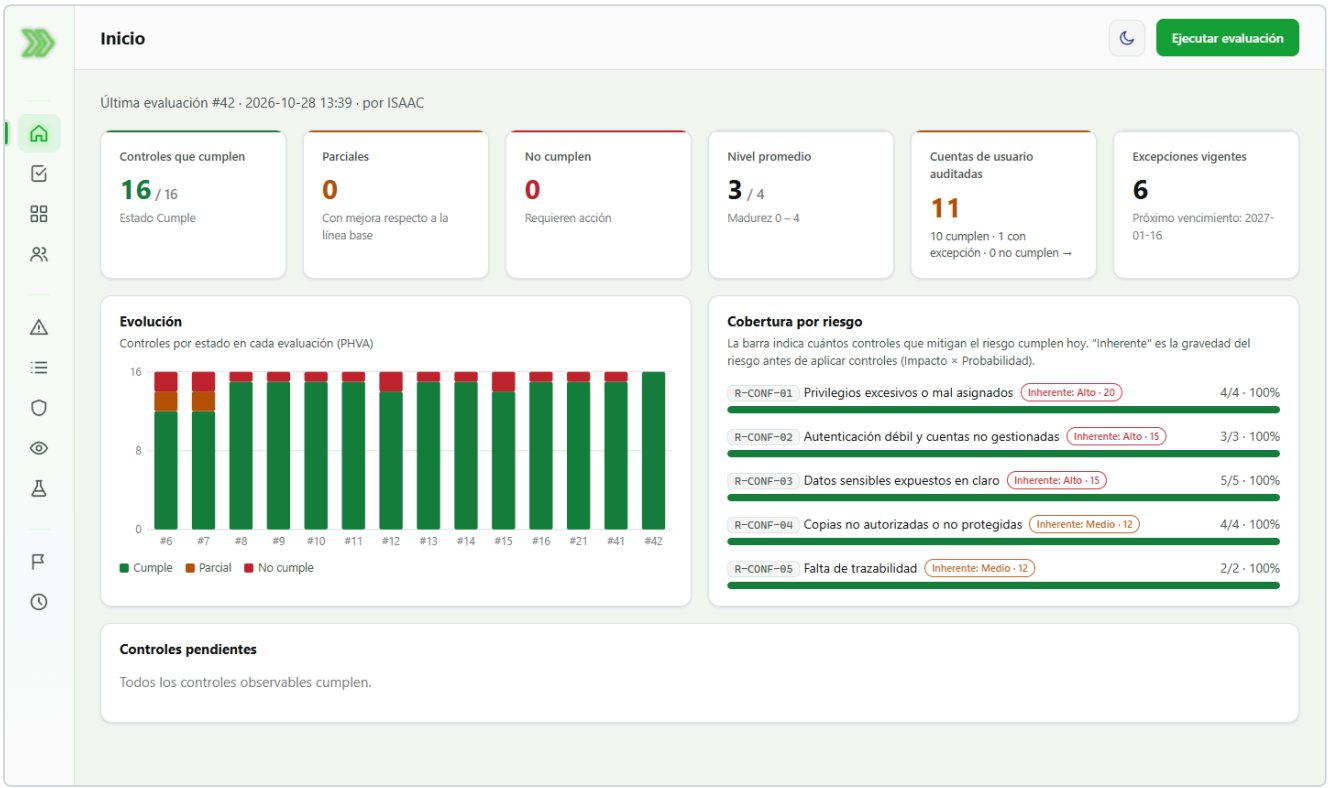


Figura 1. Pantalla de inicio: estado de la última evaluación, cuentas auditadas, evolución PHVA y cobertura por riesgo.

5.2 Tabla de riesgos de confidencialidad

Escalas: impacto (I) y probabilidad (P) de 1 a 5. Nivel = I × P (1 a 6 Bajo, 8 a 12 Medio, 15 a 25 Alto). Las dimensiones corresponden a las vistas en clase: acceso a datos, datos sensibles y copias no autorizadas.

ID	Riesgo	Dimensión	Escenario	I	P	Nivel
R-CONF-01	**Privilegios excesivos o mal asignados**	Acceso a datos	Usuarios con rol DBA, privilegios ANY o grants a PUBLIC leen datos que no les corresponden	5	4	20 Alto
R-CONF-02	**Autenticación débil y cuentas no gestionadas**	Acceso a datos	Contraseñas por defecto, sin bloqueo por intentos, cuentas inactivas abiertas o compartidas	5	3	15 Alto
R-CONF-03	**Datos sensibles expuestos en claro**	Datos sensibles	Datos personales (Ley 8968) visibles sin enmascarar en consultas, datafiles sin cifrar o tráfico de red sin cifrar	5	3	15 Alto

ID	Riesgo	Dimensión	Escenario	I	P	Nivel
R-CONF-04	**Copias no autorizadas o no protegidas**	Copias no autorizadas	Backups/exports sin cifrar, clones DEV/TEST con datos reales, datos borrados recuperables desde la papelera	4	3	12 Medio
R-CONF-05	**Falta de trazabilidad**	Transversal	Accesos y cambios de privilegios sin auditar; registros alterables; imposible investigar un fraude	4	3	12 Medio

5.3 Tabla de tareas del DBA

ID	Tarea crítica del DBA	Riesgos	Controles ISO
T-01	Gestión de usuarios (alta, baja, bloqueo de inactivos)	R-CONF-01, R-CONF-02	A5.16
T-02	Gestión de privilegios y roles	R-CONF-01	A5.15, A5.18, A8.2
T-03	Autenticación y perfiles de contraseña	R-CONF-02	A5.17, A8.5
T-04	Cifrado TDE	R-CONF-03	A8.24
T-05	Enmascaramiento / Data Redaction	R-CONF-03	A5.12, A8.11
T-06	Respaldos (RMAN / Data Pump)	R-CONF-04	A8.13
T-07	Auditoría de base de datos	R-CONF-05	A5.33, A8.15
T-08	Parcheo y actualización	R-CONF-01, R-CONF-03	A8.8
T-09	Configuración del listener y red	R-CONF-03	A8.20
T-10	Eliminación segura de información	R-CONF-04	A8.10
T-11	Gestión de logs (redo, archive, LogMiner)	R-CONF-05	A5.33, A8.15
T-12	Clones DEV/TEST	R-CONF-03, R-CONF-04	A8.11, A8.12, A8.33

5.4 Mapeo de controles ISO/IEC 27001:2022

Los controles marcados como complementarios (compl.) no están en la lista del enunciado, pero son los que corresponden en el Anexo A 2022: TDE pertenece a **A8.24 Uso de criptografía**; el parcheo a **A8.8 Gestión de vulnerabilidades técnicas** (Oracle XE no recibe parches, por lo que se documenta como riesgo aceptado con `V$VERSION` como evidencia); y los clones de desarrollo y pruebas a **A8.33 Información de prueba**.

Control	Nombre	Justificación (confidencialidad)	Implementación en Oracle	Evidencia observable
A5.12	Clasificación de la información	Identificar qué columnas contienen datos sensibles para poder protegerlas	`COMMENT ON COLUMN ... IS '[CONFIDENCIAL] ...'`	`DBA_COL_COMMENTS`
A5.15	Control de acceso	Nada se concede a PUBLIC sobre el esquema de negocio	`REVOKE ... FROM PUBLIC`	`DBA_TAB_PRIVS`
A5.16	Gestión de identidad	Cada persona tiene su propia cuenta y las cuentas inactivas se bloquean	`CREATE USER / ALTER USER ... ACCOUNT LOCK`	`DBA_USERS` (`LAST_LOGIN`, `ACCOUNT_STATUS`)
A5.17	Información de autenticación	Sin contraseñas por defecto ni algoritmos de hash débiles	`ALTER USER ... PASSWORD EXPIRE;` `SQLNET.ALLOWED_LOGON_VERSION_SERVER`	`DBA_USERS_WITH_DEFPWD`, `DBA_USERS.PASSWORD_VERSIONS`

Control	Nombre	Justificación (confidencialidad)	Implementación en Oracle	Evidencia observable
A5.18	Derechos de acceso	Los privilegios se asignan por rol y se pueden revisar	`GRANT SELECT ON ... TO vendedor; GRANT vendedor TO juan`	`DBA_TAB_PRIVS`, `DBA_ROLE_PRIVS`
A5.33	Protección de registros	Quien es auditado no puede borrar ni alterar los registros de auditoría	`Separar AUDIT_ADMIN de las cuentas DBA operativas`	`DBA_ROLE_PRIVS` (`AUDIT_ADMIN` frente a `DBA`)
A8.2	Derechos de acceso privilegiados	Mínimo privilegio en cuentas con capacidades administrativas	`REVOKE DBA / privilegios ANY innecesarios`	`DBA_SYS_PRIVS`, `DBA_ROLE_PRIVS`, `V$PWFILE_USERS`
A8.3	Restricción de acceso a la información	Cada usuario ve solo las filas que le corresponden	`Virtual Private Database: DBMS_RLS.ADD_POLICY`	`DBA_POLICIES`
A8.5	Autenticación segura	Bloqueo por intentos fallidos, complejidad de contraseña y cierre de sesión inactiva	`CREATE PROFILE con FAILED_LOGIN_ATTEMPTS, PASSWORD_VERIFY_FUNCTION, IDLE_TIME`	`DBA_PROFILES`, `DBA_USERS.PROFILE`
A8.8 (compl.)	Gestión de vulnerabilidades técnicas	Mantener el motor actualizado; en XE no hay parches, se documenta como riesgo aceptado	`Revisión de versión (V$VERSION) y plan de migración`	`V$VERSION` (versión sin parches: riesgo aceptado)
A8.10	Eliminación de información	Los datos sensibles eliminados no quedan recuperables	`DROP TABLE ... PURGE; PURGE RECYCLEBIN`	`DBA_RECYCLEBIN`
A8.11	Enmascaramiento de datos	Los datos personales se ocultan a quien no necesita verlos	`Data Redaction: DBMS_REDACT.ADD_POLICY`	`REDACTION_POLICIES`, `REDACTION_COLUMNS`
A8.12	Prevención de fuga de datos	Limitar las vías de extracción masiva (UTL_FILE, UTL_HTTP, Data Pump)	`REVOKE EXECUTE ON UTL_FILE FROM PUBLIC; controlar roles de exportación`	`DBA_TAB_PRIVS`, `DBA_ROLE_PRIVS`
A8.13	Respaldo de la información	Los respaldos que salen del servidor van cifrados	`RMAN: CONFIGURE ENCRYPTION FOR DATABASE ON`	`V$RMAN_CONFIGURATION`, `V$BACKUP_PIECE.ENCRYPTED`
A8.15	Registro (logging)	Auditar accesos a datos sensibles y el uso de privilegios	`CREATE AUDIT POLICY ...; AUDIT POLICY ...`	`AUDIT_UNIFIED_ENABLED_POLICIES`, `UNIFIED_AUDIT_TRAIL`, `V$PARAMETER`
A8.20	Seguridad de redes	El tráfico cliente-servidor viaja cifrado	`sqlnet.ora: SQLNET.ENCRYPTION_SERVER = REQUIRED`	`V$SESSION_CONNECT_INFO`, `sqlnet.ora`
A8.24 (compl.)	Uso de criptografía	Los datos en reposo (datafiles) están cifrados	`TDE: ADMINISTER KEY MANAGEMENT + tablespace cifrado`	`V$ENCRYPTION_WALLET`, `DBA_TABLESPACES.ENCRYPTED`
A8.33 (compl.)	Información de prueba	Los clones DEV/TEST no contienen datos personales reales	`Enmascarar o generar datos ficticios al clonar`	Cubierto por A8.11 y A8.12 (`REDACTION_POLICIES`, `DBA_TAB_PRIVS`)

5.5 Controles observables por un auditor externo

Cada control observable es una consulta de solo lectura que devuelve los **hallazgos**, es decir, las filas que incumplen: 0 filas significa que el control se observa implementado. Son 15 controles más uno complementario (CO-16, TDE). Las consultas completas están en el Anexo A.

ID	Control	Qué observa el auditor	Cumple si
CO-01	A5.12	Columnas con datos personales clasificadas como [CONFIDENCIAL]	Todas las columnas sensibles tienen comentario [CONFIDENCIAL]
CO-02	A5.15	Sin privilegios concedidos a PUBLIC sobre el esquema de negocio	0 privilegios a PUBLIC sobre AUDINC_DEMO
CO-03	A5.16	Cuentas abiertas sin uso en los últimos 90 días (o nunca usadas)	0 cuentas abiertas inactivas
CO-04	A5.17	Sin contraseñas por defecto ni hashes 10G en cuentas abiertas	0 cuentas con contraseña por defecto o hash 10G
CO-05	A5.18	Privilegios de objeto sobre el negocio solo a través de roles	0 privilegios de objeto otorgados directamente a usuarios
CO-06	A5.33	AUDIT_ADMIN separado de las cuentas con rol DBA	Ninguna cuenta (salvo SYS) tiene DBA y AUDIT_ADMIN a la vez
CO-07	A8.2	Sin rol DBA, privilegios ANY ni privilegios administrativos (SYSDBA, SYSBACKUP...) en cuentas no mantenidas por Oracle	0 cuentas de usuario con DBA, privilegios ANY o administrativos sin excepción aprobada
CO-08	A8.3	Política VPD habilitada sobre AUDINC_DEMO.VENTAS	Existe al menos una política VPD habilitada
CO-09	A8.5	Usuarios con contraseña asignados a un perfil seguro	0 usuarios abiertos fuera de AUDINC_SEGURO / AUDINC_SERVICIO
CO-10	A8.10	Papelera de reciclaje sin objetos del esquema de negocio	0 objetos de AUDINC_DEMO en la papelera
CO-11	A8.11	Columnas sensibles cubiertas por Data Redaction y sin exenciones	Todas las columnas sensibles con redaction y 0 usuarios exentos
CO-12	A8.12	Paquetes de extracción no ejecutables por PUBLIC y roles de exportación controlados	0 grants de UTL_* a PUBLIC y 0 usuarios con roles de exportación total
CO-13	A8.13	Respaldos RMAN configurados con cifrado	Cifrado RMAN activo y 0 piezas de respaldo sin cifrar
CO-14	A8.15	Política de auditoría AUDINC activa y auditoría de SYS habilitada	Política AUDINC_* habilitada y audit_sys_operations = TRUE
CO-15	A8.20	La sesión del evaluador viaja con cifrado de red nativo	El banner de la sesión muestra un adaptador de cifrado activo (AES)
CO-16	A8.24 (compl.)	(Complementario) Wallet TDE abierto y tablespace de negocio cifrado	Wallet OPEN y tablespace de AUDINC_DEMO cifrado

5.6 Criterio de madurez 0 a 4

El evaluador califica cada control de forma automática y reproducible a partir de los hallazgos de su consulta:

Nivel	Significado	Regla aplicada	Estado
0	Sin evidencia	La consulta de evidencia no se pudo ejecutar	No cumple
1	Inicial	Hay hallazgos y no hay mejora respecto a la línea base	No cumple
2	En implementación	Hay hallazgos, pero menos que en la línea base	Parcial
3	Implementado	0 hallazgos (o 0 hallazgos fuera de excepciones aprobadas)	Cumple
4	Sostenido	0 hallazgos en esta evaluación y en la anterior, sin depender de excepciones	Cumple

Excepciones aprobadas. Cuando un hallazgo corresponde a un riesgo aceptado formalmente (por ejemplo, un objeto de otro proyecto que comparte la instancia), se registra una excepción con justificación, control compensatorio, responsable y fecha de vencimiento. El hallazgo exceptuado no se cuenta, pero sigue visible en la evidencia, y el nivel máximo del control pasa a ser 3: un riesgo aceptado no equivale a un control implementado.

5.7 Matriz de evaluación

Resultado de la evaluación #42 (2026-10-28, auditor `ISAAC`). La evidencia de cada fila (las filas devueltas por la consulta) queda guardada en el histórico de la aplicación.

Tarea	Riesgo	Control	Criterio (control observable)	Nivel 0-4	Evidencia	Estado
T-01 Gestión de usuarios (alta, baja, bloqueo de inactivos)	R-CONF-01, R-CONF-02	A5.16 Gestión de identidad	CO-03: 0 cuentas abiertas inactivas	3	0 hallazgos	**Cumple**
T-02 Gestión de privilegios y roles	R-CONF-01	A5.15 Control de acceso	CO-02: 0 privilegios a PUBLIC sobre AUDINC_DEMO	4	0 hallazgos	**Cumple**
T-02 Gestión de privilegios y roles	R-CONF-01	A5.18 Derechos de acceso	CO-05: 0 privilegios de objeto otorgados directamente a usuarios	4	0 hallazgos	**Cumple**
T-02 Gestión de privilegios y roles	R-CONF-01	A8.2 Derechos de acceso privilegiados	CO-07: 0 cuentas de usuario con DBA, privilegios ANY o administrativos sin excepción aprobada	3	0 hallazgos	**Cumple**
T-03 Autenticación y perfiles de contraseña	R-CONF-02	A5.17 Información de autenticación	CO-04: 0 cuentas con contraseña por defecto o hash 10G	4	0 hallazgos	**Cumple**
T-03 Autenticación y perfiles de contraseña	R-CONF-02	A8.5 Autenticación segura	CO-09: 0 usuarios abiertos fuera de AUDINC_SEGURO / AUDINC_SERVICIO	3	0 hallazgos	**Cumple**
T-04 Cifrado TDE	R-CONF-03	A8.24 Uso de criptografía	CO-16: Wallet OPEN y tablespace de AUDINC_DEMO cifrado	3	0 hallazgos	**Cumple**
T-05 Enmascaramiento / Data Redaction	R-CONF-03	A5.12 Clasificación de la información	CO-01: Todas las columnas sensibles tienen comentario [CONFIDENCIAL]	4	0 hallazgos	**Cumple**
T-05 Enmascaramiento / Data Redaction	R-CONF-03	A8.11 Enmascaramiento de datos	CO-11: Todas las columnas sensibles con redaction y 0 usuarios exentos	4	0 hallazgos	**Cumple**
T-06 Respaldos (RMAN / Data Pump)	R-CONF-04	A8.13 Respaldo de la información	CO-13: Cifrado RMAN activo y 0 piezas de respaldo sin cifrar	3	0 hallazgos	**Cumple**
T-07 Auditoría de base de datos	R-CONF-05	A5.33 Protección de registros	CO-06: Ninguna cuenta (salvo SYS) tiene DBA y AUDIT_ADMIN a la vez	4	0 hallazgos	**Cumple**
T-07 Auditoría de base de datos	R-CONF-05	A8.15 Registro (logging)	CO-14: Política AUDINC_* habilitada y audit_sys_operations = TRUE	4	0 hallazgos	**Cumple**
T-08 Parcheo y actualización	R-CONF-01, R-CONF-03	A8.8 Gestión de vulnerabilidades técnicas	Sin control observable	N/A	N/A	N/A

Tarea	Riesgo	Control	Criterio (control observable)	Nivel 0-4	Evidencia	Estado
T-09 Configuración del listener y red	R-CONF-03	A8.20 Seguridad de redes	CO-15: El banner de la sesión muestra un adaptador de cifrado activo (AES)	4	0 hallazgos	**Cumple**
T-10 Eliminación segura de información	R-CONF-04	A8.10 Eliminación de información	CO-10: 0 objetos de AUDINC_DEMO en la papelera	4	0 hallazgos	**Cumple**
T-11 Gestión de logs (redo, archive, LogMiner)	R-CONF-05	A5.33 Protección de registros	CO-06: Ninguna cuenta (salvo SYS) tiene DBA y AUDIT_ADMIN a la vez	4	0 hallazgos	**Cumple**
T-11 Gestión de logs (redo, archive, LogMiner)	R-CONF-05	A8.15 Registro (logging)	CO-14: Política AUDINC_* habilitada y audit_sys_operations = TRUE	4	0 hallazgos	**Cumple**
T-12 Clones DEV/TEST	R-CONF-03, R-CONF-04	A8.11 Enmascaramiento de datos	CO-11: Todas las columnas sensibles con redaction y 0 usuarios exentos	4	0 hallazgos	**Cumple**
T-12 Clones DEV/TEST	R-CONF-03, R-CONF-04	A8.12 Prevención de fuga de datos	CO-12: 0 grants de UTL_* a PUBLIC y 0 usuarios con roles de exportación total	4	0 hallazgos	**Cumple**
T-12 Clones DEV/TEST	R-CONF-03, R-CONF-04	A8.33 Información de prueba	Sin control observable	N/A	N/A	N/A

5.8 Batería de pruebas

Las pruebas PT-01 a PT-16 las ejecuta el evaluador (una por control observable). Las pruebas funcionales PT-17 a PT-21 están en `scripts/02_verificacion/`, y PT-22 y PT-23 en `tests/`. Las salidas de cada prueba están en `evidencias/salidas/`.

ID	Tipo	Control	Procedimiento	Resultado esperado	Herramienta
PT-01	Consulta	CO-01	Ejecutar la consulta de evidencia de CO-01 (A5.12)	Todas las columnas sensibles tienen comentario [CONFIDENCIAL]	AUDINC / SQL Developer
PT-02	Consulta	CO-02	Ejecutar la consulta de evidencia de CO-02 (A5.15)	0 privilegios a PUBLIC sobre AUDINC_DEMO	AUDINC / SQL Developer
PT-03	Consulta	CO-03	Ejecutar la consulta de evidencia de CO-03 (A5.16)	0 cuentas abiertas inactivas	AUDINC / SQL Developer
PT-04	Consulta	CO-04	Ejecutar la consulta de evidencia de CO-04 (A5.17)	0 cuentas con contraseña por defecto o hash 10G	AUDINC / SQL Developer
PT-05	Consulta	CO-05	Ejecutar la consulta de evidencia de CO-05 (A5.18)	0 privilegios de objeto otorgados directamente a usuarios	AUDINC / SQL Developer
PT-06	Consulta	CO-06	Ejecutar la consulta de evidencia de CO-06 (A5.33)	Ninguna cuenta (salvo SYS) tiene DBA y AUDIT_ADMIN a la vez	AUDINC / SQL Developer
PT-07	Consulta	CO-07	Ejecutar la consulta de evidencia de CO-07 (A8.2)	0 cuentas de usuario con DBA o privilegios ANY	AUDINC / SQL Developer
PT-08	Consulta	CO-08	Ejecutar la consulta de evidencia de CO-08 (A8.3)	Existe al menos una política VPD habilitada	AUDINC / SQL Developer

ID	Tipo	Control	Procedimiento	Resultado esperado	Herramienta
PT-09	Consulta	CO-09	Ejecutar la consulta de evidencia de CO-09 (A8.5)	0 usuarios abiertos fuera de AUDINC_SEGURO / AUDINC_SERVICIO	AUDINC / SQL Developer
PT-10	Consulta	CO-10	Ejecutar la consulta de evidencia de CO-10 (A8.10)	0 objetos de AUDINC_DEMO en la papelera	AUDINC / SQL Developer
PT-11	Consulta	CO-11	Ejecutar la consulta de evidencia de CO-11 (A8.11)	Todas las columnas sensibles con redaction y 0 usuarios exentos	AUDINC / SQL Developer
PT-12	Consulta	CO-12	Ejecutar la consulta de evidencia de CO-12 (A8.12)	0 grants de UTL_* a PUBLIC y 0 usuarios con roles de exportación total	AUDINC / SQL Developer
PT-13	Consulta	CO-13	Ejecutar la consulta de evidencia de CO-13 (A8.13)	Cifrado RMAN activo y 0 piezas de respaldo sin cifrar	AUDINC / SQL Developer
PT-14	Consulta	CO-14	Ejecutar la consulta de evidencia de CO-14 (A8.15)	Política AUDINC_* habilitada y audit_sys_operations = TRUE	AUDINC / SQL Developer
PT-15	Consulta	CO-15	Ejecutar la consulta de evidencia de CO-15 (A8.20)	El banner de la sesión muestra un adaptador de cifrado activo (AES)	AUDINC / SQL Developer
PT-16	Consulta	CO-16	Ejecutar la consulta de evidencia de CO-16 (A8.24)	Wallet OPEN y tablespace de AUDINC_DEMO cifrado	AUDINC / SQL Developer
PT-17	Funcional	CO-11	Conectar como JUAN (sin EXEMPT REDACTION POLICY) y consultar AUDINC_DEMO.CLIENTES	Cédula, email y teléfono aparecen enmascarados	SQL Developer
PT-18	Funcional	CO-08	Conectar como JUAN y ejecutar SELECT * FROM AUDINC_DEMO.VENTAS	Solo se devuelven las ventas con vendedor = JUAN	SQL Developer
PT-19	Funcional	CO-09	Intentar conectar como PEDRO con contraseña incorrecta hasta superar FAILED_LOGIN_ATTEMPTS	ORA-28000: la cuenta queda bloqueada	SQL*Plus
PT-20	Funcional	CO-05	Conectar como JUAN y consultar AUDINC_DEMO.EMPLEADOS	ORA-00942 / ORA-01031: sin acceso a salarios	SQL*Plus
PT-21	Funcional	CO-14	Consultar UNIFIED_AUDIT_TRAIL después de PT-17 a PT-20	Los eventos aparecen con usuario, acción, objeto y hora	SQL Developer
PT-22	Funcional	CO-09	Login de la aplicación: sin sesión, LUIS (sin rol AUDITOR), ISAAC (AUDITOR), evaluación, cierre de sesión	401 sin sesión; 403 LUIS; ISAAC entra con cookie HttpOnly/SameSite; evaluación a nombre de ISAAC; 401 tras cerrar sesión	php tests/PT-22_login.php
PT-23	Funcional	CO-02	Ciclo Verificar -> Actuar: GRANT SELECT de CLIENTES a PUBLIC, evaluación, REVOKE, evaluación	Primera evaluación: CO-02 No cumple con el permiso como evidencia; segunda: CO-02 Cumple	php tests/PT-23_deteccion_y_correccion.php

5.9 Auditoría de las cuentas de usuario

Además de los controles generales, AUDINC revisa **cada cuenta de usuario de Oracle** de la PDB (excepto las cuentas internas de Oracle) contra 7 requisitos, con los mismos criterios y excepciones de los controles observables:

Requisito	Control	Criterio
Perfil seguro asignado	A8.5 (CO-09)	Perfil `AUDINC_SEGURO` (personas) o `AUDINC_SERVICIO` (aplicaciones)
Política de contraseñas del perfil	A5.17	Bloqueo tras 5 intentos o menos, función de complejidad, sin reutilización y vigencia de 180 días o menos
Sin contraseña por defecto ni hash 10G	A5.17 (CO-04)	No figura en `DBA_USERS_WITH_DEFPWD` ni conserva el hash 10G
Cuenta en uso	A5.16 (CO-03)	Inicio de sesión en los últimos 90 días
Sin privilegios críticos	A8.2 (CO-07)	Sin rol `DBA`, privilegios `ANY` ni administrativos (`SYSDBA`, `SYSBACKUP` ...)
Acceso a datos solo por roles	A5.18 (CO-05)	Sin privilegios de objeto directos sobre `AUDINC_DEMO`
Actividad auditada	A8.15	Cubierta por `ORA_LOGON_FAILURES` y por las políticas `AUDINC_*`

Resultado al 2026-10-28: **11 cuentas auditadas, 10 cumplen y 1 cumple con excepción** (`C##BGBACKUP`, usuario común de otro proyecto). C = Cumple, E = Exceptuado, NA = No aplica (la cuenta no puede iniciar sesión: está bloqueada o no tiene contraseña).

Cuenta	Estado	Perfil	Perfil seguro	Política	Contraseña	En uso	Privilegios	Por roles	Auditada	Resultado
AUDINC_APP	OPEN	AUDINC_SERVICIO	C	C	C	C	C	C	C	Cumple (7/7)
AUDINC_DEMO	OPEN	DEFAULT	NA	NA	NA	NA	C	C	C	Cumple (3/3)
AUDINC_OWNER	OPEN	DEFAULT	NA	NA	NA	NA	C	C	C	Cumple (3/3)
AUDINC_SEC	OPEN	DEFAULT	NA	NA	NA	NA	C	C	C	Cumple (3/3)
C##BGBACKUP	OPEN	DEFAULT	E	E	C	E	E	C	C	Cumple con excepción (3/7)
ISAAC	OPEN	AUDINC_SEGURO	C	C	C	C	C	C	C	Cumple (7/7)
JUAN	OPEN	AUDINC_SEGURO	C	C	C	C	C	C	C	Cumple (7/7)
LUIS	OPEN	AUDINC_SEGURO	C	C	C	C	C	C	C	Cumple (7/7)
PDBADMIN	LOCKED	DEFAULT	NA	NA	NA	NA	C	C	C	Cumple (3/3)
PEDRO	OPEN	AUDINC_SEGURO	C	C	C	C	C	C	C	Cumple (7/7)

Cuenta	Estado	Perfil	Perfil seguro	Política	Contraseña	En uso	Privilegios	Por roles	Auditada	Resultado
TEMPORAL	EXPIRED y LOCKED	AUDINC_SEGURO	NA	NA	NA	NA	C	C	C	Cumple (3/3)

5.10 Excepciones aprobadas

Control	Objeto exceptuado	Justificación	Control compensatorio	Vence
CO-03	`C##BGBACKUP`	Usuario común del proyecto BackupGuard (misma instancia XE); opera desde CDB$ROOT, no inicia sesión en XEPDB1.	Solo CREATE SESSION + SELECT_CATALOG_ROLE; intentos fallidos auditados por ORA_LOGON_FAILURES.	2027-01-16
CO-07	`C##BGBACKUP`	BackupGuard requiere privilegio administrativo para ejecutar RMAN.	Usa SYSBACKUP (el privilegio administrativo mínimo para respaldos) en lugar de SYSDBA; sus operaciones SYS se auditan (audit_sys_operations = TRUE).	2027-01-16
CO-09	`C##BGBACKUP`	Usuario común: su perfil se administra desde CDB$ROOT y pertenece a otro proyecto.	Sin privilegios sobre datos de negocio de XEPDB1.	2027-01-16
CO-13	`C:\APP\ISAAC\PRODUCT\21C\DBHOMEXE\DATABASE\%`	Piezas RMAN de BackupGuard (2026-10-19) guardadas en la carpeta por defecto de Oracle; AUDINC no debe modificarlas ni eliminarlas. BackupGuard ya no genera respaldos.	Ubicación local; contienen XEPDB1 solo con datos ficticios. Con A8.24 (TDE) los datos de AUDINC_DEMO quedan cifrados también dentro de los respaldos nuevos.	2027-01-16
CO-13	`C:\BACKUPGUARD_RMAN\%`	Respaldos generados por el proyecto BackupGuard; AUDINC no debe modificarlos ni eliminarlos.	Ubicación local; contienen XEPDB1 solo con datos ficticios.	2027-01-16
CO-13	`RMAN: ENCRYPTION FOR DATABASE`	La configuración RMAN es de toda la instancia; activarla cifraría también los respaldos de BackupGuard y haría depender su restauración de un keystore TDE que aún no existe.	Los respaldos se guardan localmente en un equipo de uso personal; XEPDB1 solo contiene datos ficticios. Revisar al implementar A8.24 (TDE).	2027-01-16

6. Resultados

6.1 Evolución de las evaluaciones

Evaluación	Fecha	Momento del ciclo	Cumple	Parcial	No cumple
#1	2026-10-15	Línea base, con brechas intencionales	2	0	14
#4	2026-10-15	Tras aplicar los controles internos (`01_controles`)	11	2	3
#6	2026-10-15	Tras el cifrado de red (A8.20)	12	2	2
#8	2026-10-16	Tras AC-02 (cuentas ajenas y excepciones)	15	0	1
#15	2026-10-16	PT-23 paso 1: brecha introducida a propósito (`GRANT` a `PUBLIC`)	14	0	2
#16	2026-10-16	PT-23 paso 2: brecha corregida (`REVOKE`)	15	0	1
#41	2026-10-28	Tras AC-03 (cuenta ISAAC) y AC-04 (respaldos)	15	0	1
#42	2026-10-28	Tras aplicar TDE (A8.24)	**16**	0	0

Las evaluaciones intermedias que no aparecen corresponden a corridas de prueba del propio evaluador (repetición de la línea base, pruebas de inicio de sesión). El histórico completo puede consultarse en la aplicación y no puede modificarse.

6.2 Detalle de la evaluación final (#42)

CO	Control	Hallazgos	Nivel	Estado	Justificación del nivel
CO-01	A5.12	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-02	A5.15	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-03	A5.16	0	3/4	**Cumple**	Sin hallazgos fuera de excepciones (1 exceptuado(s) por excepción aprobada vigente)
CO-04	A5.17	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-05	A5.18	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-06	A5.33	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-07	A8.2	0	3/4	**Cumple**	Sin hallazgos fuera de excepciones (1 exceptuado(s) por excepción aprobada vigente)
CO-08	A8.3	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-09	A8.5	0	3/4	**Cumple**	Sin hallazgos fuera de excepciones (1 exceptuado(s) por excepción aprobada vigente)
CO-10	A8.10	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-11	A8.11	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)

CO	Control	Hallazgos	Nivel	Estado	Justificación del nivel
CO-12	A8.12	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-13	A8.13	0	3/4	**Cumple**	Sin hallazgos fuera de excepciones (8 exceptuado(s) por excepción aprobada vigente)
CO-14	A8.15	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-15	A8.20	0	4/4	**Cumple**	Sin hallazgos en esta evaluación ni en la anterior (control sostenido)
CO-16	A8.24	0	3/4	**Cumple**	Sin hallazgos

6.3 Acciones correctivas (fase Actuar)

- **AC-01. Revocación de `UTL_*` a `PUBLIC` (A8.12).** La primera versión del control invalidó 123 objetos de componentes internos de Oracle que dependían de esos paquetes. El propio script detectó los objetos inválidos y se revirtió el cambio en minutos. La segunda versión calcula desde `DBA_DEPENDENCIES` qué esquemas necesitan cada paquete, les otorga el permiso de forma explícita y solo entonces revoca el acceso a `PUBLIC`, con reversión automática si aparece algún objeto inválido. Lección: una recomendación de endurecimiento debe probarse antes de aplicarse en producción.
- **AC-02. Cuentas ajenas y riesgos aceptados.** La cuenta `PDBADMIN`, creada por el instalador de XE y nunca usada, se bloqueó. Para el usuario común `C##BGBACKUP` (otro proyecto que comparte la instancia, con privilegio `SYSBACKUP`) y sus respaldos RMAN sin cifrar se registraron excepciones con vencimiento. El control CO-07 se amplió para detectar privilegios administrativos mediante `V$PWFILE_USERS`.
- **AC-03. Cuenta nominal del auditor.** La cuenta de prueba `ANA` se reemplazó por `ISAAC`, cuenta del responsable de la auditoría, para que cada evaluación y cada evento del rastro queden a nombre de una persona identificable. El histórico anterior no se reescribió.
- **AC-04. Respaldos fuera de la ubicación exceptuada.** Se detectaron piezas RMAN sin cifrar del otro proyecto en la carpeta por defecto de Oracle; se registró la excepción correspondiente.

6.4 Prueba de detección y corrección (PT-23)

PT-23 demuestra el ciclo Verificar y Actuar de forma automática: otorga `SELECT` sobre `AUDINC_DEMO.CLIENTES` a `PUBLIC`, ejecuta una evaluación (CO-02 pasa a No cumple y el permiso aparece como evidencia), revoca el permiso y evalúa de nuevo (CO-02 vuelve a Cumple). El `REVOKE` se ejecuta siempre, aunque la prueba falle.

7. Conclusiones y recomendaciones

7.1 Conclusiones

1. Los controles de confidencialidad del Anexo A de ISO/IEC 27001:2022 pueden traducirse a configuraciones concretas de Oracle y verificarse con consultas al diccionario de datos. Esto convierte la auditoría en un proceso repetible y objetivo.
2. Medir antes de corregir fue decisivo: la línea base (2 de 16) y la evaluación final (16 de 16) muestran el efecto de cada fase del ciclo PHVA, y la propia medición detectó un efecto colateral grave (AC-01) que se corrigió antes de que causara daño.

3. En una instancia compartida, varios controles (cifrado de red, TDE, configuración RMAN) afectan a todos los proyectos. Las excepciones con justificación, control compensatorio y vencimiento permiten gestionar ese riesgo de forma transparente, sin ocultarlo.
4. La aplicación del evaluador también es un activo que protege: delegar la autenticación en Oracle, aplicar mínimo privilegio a su cuenta de servicio y hacer inalterable su evidencia evita que el evaluador se convierta en una nueva brecha de confidencialidad.

7.2 Recomendaciones y trabajo futuro

- **Copia externa de la auditoría (mini-SIEM).** Enviar periódicamente los eventos de `UNIFIED_AUDIT_TRAIL` a un sistema separado donde la cuenta receptora solo pueda insertar. AUDINC podría comparar ambas copias y detectar la manipulación del rastro como un nuevo control observable (A5.33, A8.15).
- **TLS (TCPS) además del cifrado nativo**, para autenticar al servidor mediante certificados.
- **Cifrado de los respaldos RMAN** (A8.13) una vez que la instancia deje de ser compartida, aprovechando el keystore de TDE ya configurado.
- **Revisión de las excepciones** antes de su vencimiento (2027-01-16), según lo exigen A5.15 y A5.18.

8. Uso ético y documentado de inteligencia artificial

Durante el proyecto se utilizó **Claude** (Anthropic), mediante la herramienta Claude Code, como asistente para diseñar, programar, ejecutar pruebas y redactar documentación. Cada sesión quedó registrada en un archivo de registro de prompts. Las decisiones de alcance, aprobación de cambios en la instancia y validación de resultados fueron del estudiante.

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / corrección del estudiante	Fuente verificada
Claude (Claude Code)	Solicitud inicial de diseño de la arquitectura del proyecto a partir del enunciado (texto exacto no conservado)	Propuesta de arquitectura, estructura de carpetas por fase PHVA, criterios de nombrado y `.gitignore`	Aprobó la estructura; decidió usar Oracle 21c XE local y GitHub	Enunciado del proyecto; ISO/IEC 27001:2022
Claude (Claude Code)	"que seria mejor?" / "ok"	Script de verificación del entorno y borrador del catálogo: 5 riesgos, 12 tareas, mapeo ISO, 15 controles observables, criterio 0 a 4	Revisó el catálogo; decidió incluir A8.24, A8.8 y A8.33 como complementarios	ISO/IEC 27002:2022 (atributos de confidencialidad); salida de `00_verificar_entorno.sql`
Claude (Claude Code)	"lo veo bien, si fuera el caso en algun futuro te comento el cambio"	Scripts de setup: esquemas, roles, usuarios, catálogo en tablas, cuenta `AUDINC_APP` con mínimo privilegio, brechas intencionales	Aprobó guardar el catálogo en Oracle en lugar de JSON; se corrigió un error `ORA-01799` en la vista de la matriz	Oracle Database Security Guide 21c
Claude (Claude Code)	"yo no pensaba usar wamp, porque en teoria instale la extension oci8 ya en mi pc para que funcionara el oracle" / "si esa es una forma segura,si"	Backend PHP con OCI8 sin frameworks, API REST, criterio de madurez automático	Decidió no usar WAMP; se verificó que `AUDINC_APP` no puede modificar la evidencia (`ORA-01031`)	Manual de PHP (OCI8); pruebas propias
Claude (Claude Code)	"el video es casi lo ultimo que hare porque debo de presentar una version preliminar al profesor antes. Seguimos con el backend diria, el frontend dejemoslo casi al final cuando el backend ya este completo"	Scripts de controles (fase Hacer) y pruebas PT-17 a PT-21; detectó y revirtió el incidente AC-01	Aprobó A8.20 (cifrado de red); pospuso TDE y el cifrado RMAN por la instancia compartida	Oracle Database Security Guide 21c; salidas de PT-17 a PT-21
Claude (Claude Code)	"es que ese proyecto de backupgaurd lo debo de presentar el lunes y no me gustaria que tuviera interferencias, podrias crearme un .md [...] es decir un interruptor entre ambos proyectos" / "si"	Interruptor AUDINC/BackupGuard, documento de contexto, acción correctiva AC-02 y excepciones con vencimiento	Aprobó bloquear `PDBADMIN` y exceptuar los objetos del otro proyecto	ISO/IEC 27002:2022 (5.15, 5.18); `V$PWFILE_USERS`
Claude (Claude Code)	"ya hice commit continuemos"	Endpoint de resumen y revisión de seguridad del backend (rutas, CSP, tiempo máximo de consulta)	Revisó los hallazgos y su corrección	Pruebas propias (respuestas 404 y cabeceras)

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / corrección del estudiante	Fuente verificada
Claude (Claude Code)	"odado que queda un registro, entonces el mismo usuario que ingreso puede ver su registro?" / "descartemos mysql del todo y usemos tu propuesta de oracle, lo puedo dejar anotado como idea para presentarla ante el profesor"	Inicio de sesión delegado a Oracle, rol `AUDITOR`, trazabilidad con `CLIENT_IDENTIFIER`, prueba PT-22	Descartó MySQL para identidades; dejó la copia externa de auditoría como idea futura	ISO/IEC 27002:2022 (5.16, 5.17); PT-22 (9 de 9 casos)
Claude (Claude Code)	"entonces mejor eso del TDE lo dejamos para despues del lunes continuemos con el frontend"	Interfaz web sin frameworks, con CSP y protección contra XSS	Definió el diseño de referencia (menú lateral)	Recorrido en navegador: 0 errores de JavaScript y de CSP
Claude (Claude Code)	"y digamos como se ejcuta una evaluacion? que hace?" / "como se haria para tener guardado esa prueba?"	Prueba PT-23 de detección y corrección de una brecha	Revisó la salida de la prueba	`evidencias/salidas/PT-23_deteccion_y_correccion.txt`
Claude (Claude Code)	"Quiero cambiar el tono de la pagina a uno que sea como negro, que el menu al lado izquierdo se pueda desplegar [...]"	Tema oscuro con acento neón, menú desplegable y modo día/noche	Eligió el estilo visual y la imagen de referencia	Verificación visual
Claude (Claude Code)	"puedes hacer que esta seccion o lo que cubre, sea mas interactivo [...] que dure aproximadamente 2segundos"	Animación de la cobertura por riesgo; separación visual entre riesgo inherente y cobertura	Detectó que los colores podían confundir al lector y pidió corregirlo	Verificación visual
Claude (Claude Code)	"puedes hacer que el readme en github web se vea mas llamativo [...] es necesario la parte de PHVA?"	README con imágenes SVG propias	Decidió mantener la metodología PHVA en el README	Verificación visual en GitHub
Claude (Claude Code)	"El profesor me pidio realizar una serie de cambios [...] que al ingresar en la primera ventana que es la de resumen, se indique la cantidad de perfiles auditados [...]" / "con perfiles me refiero a las cuentas de los usuarios en oracle [...] requiero cambiar o renombrar el usuario de Ana por Isaac"	Sección de auditoría por cuenta de usuario, indicador en el inicio, AC-03, AC-04 y script de TDE corregido	Definió el alcance ("todas las cuentas"); aprobó TDE y lo ejecutó en la instancia	Oracle Database Advanced Security Guide 21c; evaluación #42 (16 de 16)
Claude (Claude Code)	"necesito generar un .md con todo lo solicitado en la parte de documentación del proyecto y luego necesito que ese .md pase a ser pdf [...]"	Borrador de este informe, manual de usuario y manual técnico, conversión a PDF	Revisión del contenido y de las referencias antes de la entrega	Enunciado del proyecto (secciones 5 a 10)

Declaración jurada

Yo, **Isaac Naranjo**, declaro que todo contenido generado con IA ha sido declarado en la tabla anterior, validado contra fuentes oficiales (ISO, documentación del motor de base de datos) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

Isaac Naranjo Firma	Fecha

9. Referencias

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley N.° 8968: Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. Sistema Costarricense de Información Jurídica. http://www.pgrweb.go.cr/scij/

International Organization for Standardization. (2022a). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection: Information security management systems: Requirements*. ISO.

International Organization for Standardization. (2022b). *ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection: Information security controls*. ISO.

Kent, K., y Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92

Oracle. (2021a). *Oracle Database Advanced Security guide, 21c*. Oracle Corporation. https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/

Oracle. (2021b). *Oracle Database Security guide, 21c*. Oracle Corporation. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/

Oracle. (2021c). *Oracle Database Express Edition licensing information user manual, 21c*. Oracle Corporation. https://docs.oracle.com/en/database/oracle/oracle-database/21/xelic/

Poder Ejecutivo de la República de Costa Rica. (2013). *Decreto Ejecutivo N.° 37554-JP: Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. Sistema Costarricense de Información Jurídica. http://www.pgrweb.go.cr/scij/

Rose, S., Borchert, O., Mitchell, S., y Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Saltzer, J. H., y Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278-1308. https://doi.org/10.1109/PROC.1975.9939

Anexo A. Consultas de evidencia de los controles observables

Cada consulta devuelve los hallazgos (filas que incumplen). Pueden ejecutarse en SQL Developer con una cuenta que tenga acceso de lectura al diccionario de datos.

CO-01 · A5.12 · Columnas con datos personales clasificadas como [CONFIDENCIAL]

Cumple si: Todas las columnas sensibles tienen comentario [CONFIDENCIAL]

```
SELECT c.table_name, c.column_name
FROM dba_tab_columns c
LEFT JOIN dba_col_comments m
  ON m.owner = c.owner AND m.table_name = c.table_name AND m.column_name = c.column_name
WHERE c.owner = 'AUDINC_DEMO'
  AND c.table_name NOT LIKE 'BIN$%'
  AND REGEXP_LIKE(c.column_name, 'CEDULA|EMAIL|TELEFONO|DIRECCION|SALARIO')
  AND (m.comments IS NULL OR m.comments NOT LIKE '[CONFIDENCIAL]%')
```

CO-02 · A5.15 · Sin privilegios concedidos a PUBLIC sobre el esquema de negocio

Cumple si: 0 privilegios a PUBLIC sobre AUDINC_DEMO

```
SELECT table_name, privilege
FROM dba_tab_privs
WHERE owner = 'AUDINC_DEMO'
  AND grantee = 'PUBLIC'
```

CO-03 · A5.16 · Cuentas abiertas sin uso en los últimos 90 días (o nunca usadas)

Cumple si: 0 cuentas abiertas inactivas

```
SELECT username, account_status, TO_CHAR(last_login, 'YYYY-MM-DD HH24:MI') AS last_login
FROM dba_users
WHERE oracle_maintained = 'N'
  AND authentication_type = 'PASSWORD'
  AND account_status = 'OPEN'
  AND (last_login IS NULL OR last_login < SYSTIMESTAMP - INTERVAL '90' DAY)
```

CO-04 · A5.17 · Sin contraseñas por defecto ni hashes 10G en cuentas abiertas

Cumple si: 0 cuentas con contraseña por defecto o hash 10G

```
SELECT d.username, 'Contrasena por defecto' AS hallazgo
FROM dba_users_with_defpwd d
JOIN dba_users u ON u.username = d.username
WHERE u.account_status = 'OPEN'
UNION ALL
SELECT username, 'Hash 10G habilitado'
FROM dba_users
WHERE account_status = 'OPEN'
  AND password_versions LIKE '%10G%'
```

CO-05 · A5.18 · Privilegios de objeto sobre el negocio solo a través de roles

Cumple si: 0 privilegios de objeto otorgados directamente a usuarios

```
SELECT grantee, table_name, privilege
FROM dba_tab_privs
WHERE owner = 'AUDINC_DEMO'
  AND grantee IN (SELECT username FROM dba_users)
```

CO-06 · A5.33 · AUDIT_ADMIN separado de las cuentas con rol DBA

Cumple si: Ninguna cuenta (salvo SYS) tiene DBA y AUDIT_ADMIN a la vez

```
SELECT grantee
FROM dba_role_privs
WHERE granted_role = 'AUDIT_ADMIN'
  AND grantee <> 'SYS'
  AND grantee IN (SELECT grantee FROM dba_role_privs WHERE granted_role = 'DBA')
```

CO-07 · A8.2 · Sin rol DBA, privilegios ANY ni privilegios administrativos (SYSDBA, SYSBACKUP...) en cuentas no mantenidas por Oracle

Cumple si: 0 cuentas de usuario con DBA, privilegios ANY o administrativos sin excepción aprobada

```
SELECT grantee, privilege AS privilegio
FROM dba_sys_privs
WHERE privilege LIKE '%ANY%'
  AND grantee IN (SELECT username FROM dba_users WHERE oracle_maintained = 'N')
UNION ALL
SELECT grantee, granted_role
FROM dba_role_privs
WHERE granted_role = 'DBA'
  AND grantee IN (SELECT username FROM dba_users WHERE oracle_maintained = 'N')
UNION ALL
SELECT username,
       'Administrativo: ' || RTRIM(DECODE(sysdba, 'TRUE', 'SYSDBA ') || DECODE(sysoper, 'TRUE', 'SYSOPER
') ||
                                   DECODE(sysbackup, 'TRUE', 'SYSBACKUP ') || DECODE(sysdg, 'TRUE', 'SYSDG
') ||
                                   DECODE(syskm, 'TRUE', 'SYSKM '))
FROM v$pwfile_users
WHERE username IN (SELECT username FROM dba_users WHERE oracle_maintained = 'N')
```

CO-08 · A8.3 · Política VPD habilitada sobre AUDINC_DEMO.VENTAS

Cumple si: Existe al menos una política VPD habilitada

```
SELECT 'AUDINC_DEMO.VENTAS' AS tabla, 'Sin politica VPD habilitada' AS hallazgo
FROM dual
WHERE NOT EXISTS (SELECT 1 FROM dba_policies
                  WHERE object_owner = 'AUDINC_DEMO'
                    AND object_name  = 'VENTAS'
                    AND enable       = 'YES')
```

CO-09 · A8.5 · Usuarios con contraseña asignados a un perfil seguro

Cumple si: 0 usuarios abiertos fuera de AUDINC_SEGURO / AUDINC_SERVICIO

```
SELECT username, profile
FROM dba_users
WHERE oracle_maintained = 'N'
  AND authentication_type = 'PASSWORD'
  AND account_status = 'OPEN'
  AND profile NOT IN ('AUDINC_SEGURO', 'AUDINC_SERVICIO')
```

CO-10 · A8.10 · Papelera de reciclaje sin objetos del esquema de negocio

Cumple si: 0 objetos de AUDINC_DEMO en la papelera

```
SELECT original_name, type, droptime
FROM dba_recyclebin
WHERE owner = 'AUDINC_DEMO'
```

CO-11 · A8.11 · Columnas sensibles cubiertas por Data Redaction y sin exenciones

Cumple si: Todas las columnas sensibles con redaction y 0 usuarios exentos

```
SELECT c.table_name AS objeto, c.column_name AS detalle
FROM dba_tab_columns c
WHERE c.owner = 'AUDINC_DEMO'
  AND c.table_name NOT LIKE 'BIN$%'
  AND REGEXP_LIKE(c.column_name, 'CEDULA|EMAIL|TELEFONO|DIRECCION|SALARIO')
  AND NOT EXISTS (SELECT 1 FROM redaction_columns r
                  WHERE r.object_owner = c.owner
                    AND r.object_name  = c.table_name
                    AND r.column_name  = c.column_name)
UNION ALL
SELECT grantee, privilege
FROM dba_sys_privs
WHERE privilege = 'EXEMPT REDACTION POLICY'
  AND grantee IN (SELECT username FROM dba_users WHERE oracle_maintained = 'N')
```

CO-12 · A8.12 · Paquetes de extracción no ejecutables por PUBLIC y roles de exportación controlados

Cumple si: 0 grants de UTL_* a PUBLIC y 0 usuarios con roles de exportación total

```
SELECT grantee, table_name AS objeto
FROM dba_tab_privs
WHERE grantee = 'PUBLIC'
  AND owner = 'SYS'
  AND table_name IN ('UTL_FILE', 'UTL_HTTP', 'UTL_TCP', 'UTL_SMTP')
UNION ALL
SELECT grantee, granted_role
FROM dba_role_privs
WHERE granted_role IN ('DATAPUMP_EXP_FULL_DATABASE', 'EXP_FULL_DATABASE')
  AND grantee IN (SELECT username FROM dba_users WHERE oracle_maintained = 'N')
```

CO-13 · A8.13 · Respaldos RMAN configurados con cifrado

Cumple si: Cifrado RMAN activo y 0 piezas de respaldo sin cifrar

```
SELECT 'RMAN: ENCRYPTION FOR DATABASE' AS objeto, 'Cifrado de respaldos no configurado' AS hallazgo
FROM dual
WHERE NOT EXISTS (SELECT 1 FROM v$rman_configuration
                  WHERE name = 'ENCRYPTION FOR DATABASE' AND value = 'ON')
UNION ALL
SELECT handle, 'Pieza de respaldo sin cifrar'
FROM v$backup_piece
WHERE encrypted = 'NO'
  AND status = 'A'
```

CO-14 · A8.15 · Política de auditoría AUDINC activa y auditoría de SYS habilitada

Cumple si: Política AUDINC_* habilitada y audit_sys_operations = TRUE

```
SELECT 'Sin politica de auditoria AUDINC_* habilitada' AS hallazgo
FROM dual
WHERE NOT EXISTS (SELECT 1 FROM audit_unified_enabled_policies
                  WHERE policy_name LIKE 'AUDINC%')
UNION ALL
SELECT 'audit_sys_operations = ' || value
FROM v$parameter
WHERE name = 'audit_sys_operations'
  AND UPPER(value) <> 'TRUE'
```

CO-15 · A8.20 · La sesión del evaluador viaja con cifrado de red nativo

Cumple si: El banner de la sesión muestra un adaptador de cifrado activo (AES)

```
SELECT 'Sesion sin cifrado de red' AS hallazgo
FROM dual
WHERE NOT EXISTS (SELECT 1 FROM v$session_connect_info
                  WHERE sid = SYS_CONTEXT('USERENV', 'SID')
                    AND network_service_banner LIKE '%Encryption service adapter%')
```

CO-16 · A8.24 · (Complementario) Wallet TDE abierto y tablespace de negocio cifrado

Cumple si: Wallet OPEN y tablespace de AUDINC_DEMO cifrado

```
SELECT 'Wallet TDE: ' || status AS hallazgo
FROM v$encryption_wallet
WHERE con_id = SYS_CONTEXT('USERENV', 'CON_ID')
  AND status <> 'OPEN'
UNION ALL
SELECT 'Tablespace sin cifrar: ' || tablespace_name
FROM dba_tablespaces
WHERE tablespace_name IN (SELECT default_tablespace FROM dba_users WHERE username = 'AUDINC_DEMO')
  AND encrypted = 'NO'
```

Anexo B. Scripts entregados

Carpeta	Fase	Contenido
`scripts/00_setup/`	Planificar	`00_instalar.sql` (maestro), verificación del entorno, esquema de prueba, roles y usuarios, catálogo, cuenta del evaluador
`scripts/01_controles/`	Hacer	Un script por control: `A5.12`, `A5.15_A5.18_A8.2`, `A5.16`, `A5.17_A8.5`, `A8.3`, `A8.10`, `A8.11`, `A8.12`, `A8.15`, `A8.20` (procedimiento), `A8.24` (TDE), `A8.13` (RMAN)
`scripts/02_verificacion/`	Verificar	Pruebas funcionales PT-17 a PT-21 y su script maestro

Carpeta	Fase	Contenido
`scripts/03_correccion/`	Actuar	AC-01 a AC-04
`scripts/99_limpieza.sql`		Elimina todos los objetos de AUDINC
`tests/`	Verificar	PT-22, PT-23 y pruebas unitarias del criterio de madurez
`evidencias/salidas/`	Verificar	Salidas de las pruebas funcionales